

## Examples questions based on lecture 4-5

1. A multinational bank, SecureFin Corp, is implementing a new customer authentication system for online and offline transactions. The security team must ensure that every user can be reliably authenticated based on different identity factors — including what the user knows, has, is, can do, or has done. The team is considering options like smart cards, PINs, fingerprints, behavioural analysis, and digital signatures. Your task is to analyze the following situations and select the most appropriate authentication factor(s) being applied. A SecureFin customer logs into the bank's portal using a username and password combination.

Which authentication factor is being used?

- A. Something the user has
- B. Something the user knows
- C. Something the user is
- D. Something the user can do

2. Katrina works as a cybersecurity analyst in a mid-sized software company. The organization recently experienced multiple account lockouts and phishing attempts, prompting the IT security team to revise its password policy.

Under the old system, users were required to create passwords that were:

- 8 characters long,
- contained a mix of uppercase, lowercase, numbers, and special symbols,
- and had to be changed every 45 days.

Many employees complained that the rules made passwords hard to remember, leading them to write them down or reuse similar passwords across systems.

To address this, Katrina suggests allowing passphrases instead of complex passwords. A passphrase, she explains, could be a longer sequence of words, such as:

"SunnyHillsAreBeautifulInJune!" This approach, she argues, could be both easier to remember and more resistant to brute-force attacks.

As the company's security consultant, you are asked to evaluate Katrina's proposal.

Which of the following statements correctly explains why a passphrase-based policy may be more secure and user-friendly than a traditional password policy?

A. Passphrases are typically longer, increasing entropy and making them harder to crack through brute-force attacks while remaining easier for users to remember.

B. Passphrases Improve usability and does not contain errors in typing.

C. Passphrases require frequent changes to maintain their strength, similar to traditional passwords.

D. Passphrases rely solely on personal memory and therefore do not enhance security compared to short passwords.

3. In the Kerberos protocol, the Ticket Granting Ticket (TGT) issued by the AS is primarily used for:

A. Logging the user's session activity

B. Requesting tickets for specific services from the TGS without re-entering credentials

C. Encrypting communication between the client and service server

D. Storing the client's password

4. A hospital's information system uses an **Access Control Matrix (ACM)** to manage permissions.

The system defines:

**Subjects (S):** Doctor, Nurse, Receptionist, LabTechnician

**Objects (O):** PatientRecord, MedicationList, BillingData

**Rights (R):** read, write, update, delete

The matrix *A* is defined as follows:

| Subjects ↓ / Objects → | PatientRecord         | MedicationList | BillingData   |
|------------------------|-----------------------|----------------|---------------|
| Doctor                 | {read, write, update} | {read, write}  | {}            |
| Nurse                  | {read, update}        | {read}         | {}            |
| Receptionist           | {read}                | {}             | {read, write} |
| LabTechnician          | {read}                | {read, update} | {}            |

The hospital administrator wants to implement a security policy where **no subject except doctors can modify patient medical information**, and **receptionists can only view non-medical data**.

Based on the Access Control Matrix above, which of the following statements is **TRUE**?

- A. The policy is already satisfied — only doctors have write access to PatientRecord and MedicationList.
  - B. The policy is violated — nurses have update rights on PatientRecord, which allows modification.
  - C. The policy is violated — lab technicians have update rights on BillingData.
  - D. The policy is violated — receptionists have write access to MedicationList.
5. Which access control model becomes difficult to manage as the number of users increases because permissions are assigned individually?
- A. Role-Based Access Control (RBAC)
  - B. Attribute-Based Access Control (ABAC)
  - C. Identity-Based Access Control (IBAC)
  - D. Mandatory Access Control (MAC)
6. In a military system, user **Alice** has a “**Secret**” clearance and document **D1** is marked “**Top Secret**.”
- According to the **Bell–LaPadula model**, which action is **prohibited**?
- A. Alice reads D1
  - B. Alice writes to a Secret document
  - C. Alice writes to a Confidential document
  - D. Alice reads a Confidential document